

Compliance



Shweta A. Chawla
Founder & Investigator
SC Cyber Solutions



Stakeholders in Cyberspace





Cyber Threats

Cyber Crimes

- 🦋 Malware
- 🦋 Financial
- 🦋 Unauthorised access
- 🦋 Espionage

Natural Disasters

- 🦋 Earthquakes
- 🦋 Floods

Cyber Attacks

- 🦋 Malware
- 🦋 DoS
- 🦋 Misinformation
- 🦋 Critical Infrastructure Attacks
 - 🦋 Banking
 - 🦋 Power
 - 🦋 Water
 - 🦋 GPS
 - 🦋 Internet



Protection against Cyber Threats

Technological

🔴 Proactive

- ✔ AV
- ✔ IDS
- ✔ IPS
- ✔ SIEM
- ✔ Pentesting
- ✔ Secure coding
- ✔ Monitoring

🔴 Reactive

- ✔ Investigation
- ✔ Risk mitigation
- ✔ Evolution

Protection against Cyber Threats



Human

🔴 Proactive

- ✔ Awareness
- ✔ Training
- ✔ Vigilance
- ✔ Governance
- ✔ Policy
- ✔ Legislation

🔴 Reactive

- ✔ Insurance
- ✔ Litigation

Policy



- ❶ A course or principle of action adopted or proposed by the governing body of a government, business, or individual
- ❷ It is a deliberate set of guidelines to achieve outcomes
- ❸ A statement of intent
- ❹ A policy can help with subjective and objective decision making

WHY SOMETHING IS DONE



Standard

- ❶ Stipulates uniform (hence standard) use of something
- ❷ Applies to technology, settings, configuration
- ❸ Could be internal or by a third party
- ❹ Often helps an user/organization comply with a policy

WHAT IS DONE

Procedure



- ➊ Mandatory steps to be followed to achieve a desired outcome, usually a task or a policy outcome
- ➋ Often takes the form of a checklist
- ➌ Informs users on how to implement a policy
- ➍ Mandatory in nature

HOW SOMETHING IS DONE

Guideline



- ❶ Provides information, advice and guidance
- ❷ General in nature
- ❸ Usually aligned towards a policy
- ❹ Guidelines offer suggestions
- ❺ Following guidelines is a voluntary activity
- ❻ Provide flexibility for unexpected situations / circumstances



What is Compliance?

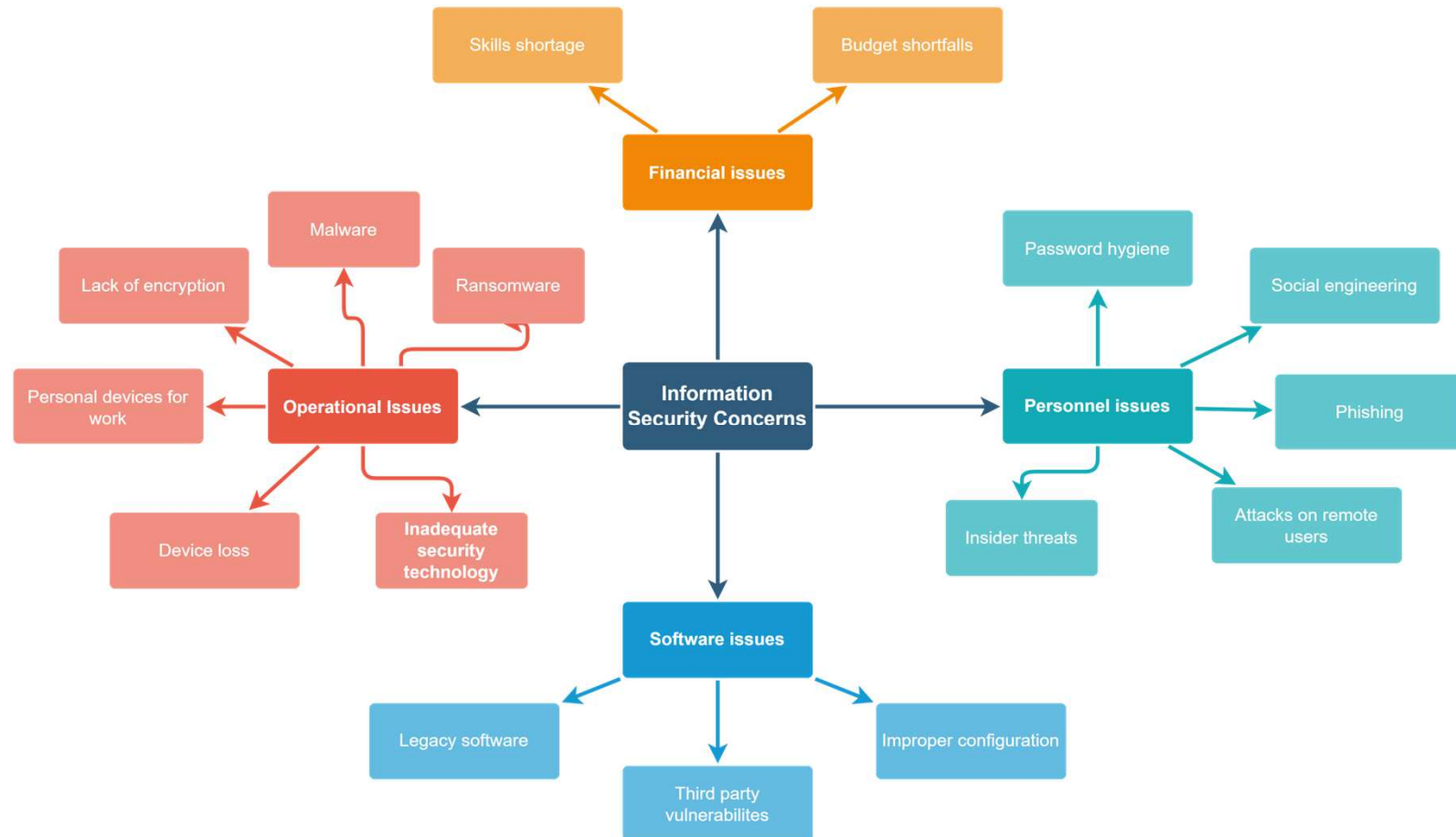
- ❶ The act of obeying an order, rule or request
 - ❷ Conformity in fulfilling official requirements
 - ❸ Conforming to a specification, standard or law that has been clearly defined
 - ❹ The state of being in accordance with established guidelines or specifications, or the process of becoming so.
-
- ❶ Audit: an official examination of the present state of something
 - ❷ IT audit: Auditing of information technology, computer systems, networks, etc.



- ❶ Compliance means conforming to
 - ❧ Laws
 - ❧ Regulations
 - ❧ Policies
 - ❧ Procedures
 - ❧ Obligations



InfoSec Concerns





Security Audit

- ❶ A security audit
 - ❧ Many ways organisations test and assess their overall security posture incl cyber security
 - ❧ A comprehensive assessment of the organization's information system
 - ❧ Typically, this assessment measures information system's security against an audit checklist of industry best practices, externally established standards, or federal regulations



- ❶ Security audits will help
 - ❧ protect critical data
 - ❧ identify security loopholes
 - ❧ create new security policies
 - ❧ track the effectiveness of security strategies

- ❷ Regular audits can help ensure employees stick to security practices and can catch new vulnerabilities.



Benefits of Security Audit

- 🦋 Test adequacy of current security strategy
- 🦋 Test security training efforts
- 🦋 Uncover extraneous hardware and software
- 🦋 Reduce costs by removing unnecessary resources
- 🦋 Identify flaws in new technology or processes
- 🦋 Verify compliance with regulations

Types of Security Audits



- 🦊 Risk assessment
- 🦊 Vulnerability assessment
- 🦊 Penetration testing
- 🦊 Compliance audit



Types of Security Audits

- 🦊 Internal audits
- 🦊 External audits
- 🦊 Ideally all stakeholders must be involved in the process

Internal Audit Team



- ❶ Why does an Internal Audit Team exist?
 - ❧ Assurance that internal controls exist and are functioning
 - ❧ Improve the state of these internal controls
 - ❧ Reporting security issues
 - ❧ Monitoring mitigation

- ❷ Qualities of an auditor
 - ❧ Objective
 - ❧ Unbiased



Qualities of an Auditor

- 🦊 Ability and willingness to dig into details without getting lost in them
- 🦊 Analytical skills
- 🦊 Written and oral communication skills
- 🦊 Ability to learn new technology / areas
- 🦊 Ability to look for areas of weakness and risk quickly
- 🦊 Relationship building



Phases of a Security Audit

- ❶ **Pre-audit agreement**
 - ✓ Scope and objectives
 - ✓ Level of support provided
 - ✓ Locations, duration
 - ✓ Financial considerations
 - ✓ Audit protocols
 - ✓ NDAs etc
- ❷ **Initiation and planning**
 - ✓ Risk assessment
 - ✓ Research
 - ✓ Preliminary review
 - ✓ Audit objective
 - ✓ Formal agreement
 - ✓ Entrance conference
- ❸ **Fieldwork**
 - ✓ Interview
 - ✓ Inspection
 - ✓ Observation
 - ✓ Re-performance
- ✓ Testing
- ❹ **Analysis**
 - ✓ Confirmation
 - ✓ Verification
 - ✓ Reconciliation
 - ✓ Exit conference
- ❺ **Reporting**
 - ✓ Findings
 - ✓ Recommendations
 - ✓ Client responses
 - ✓ Draft reports
 - ✓ Final report
 - ✓ Schedule client corrective action report
 - ✓ Plan for follow-up engagement
- ❻ **Follow-up**
 - ✓ Confirm corrective action
 - ✓ Address challenges
 - ✓ Repeat phases (As necessary)



Audit Workflow

🔴 Define assessment criteria

- ✔ Clearly define goals at onset
- ✔ Determine overall objectives and then break them down into departmental priorities
- ✔ Agree on how the audit is performed and tracked
- ✔ Maintain a record of out-of-scope items and things being exempted
- ✔ Take into account
 - ✔ Industry and geographic standards
 - ✔ Create and maintain a threat catalog of all discovered threat vectors
 - ✔ Decide on stakeholder involvement and their ability/permission to participate
 - ✔ Use outside resources if and when possible

🔴 Prepare the security audit

- ✔ Prioritise success criteria and business objectives
- ✔ Select the tools and methodologies to meet the goals
- ✔ Find or create methods to gather the correct data



🔴 Conduct the security audit

- ✔ Avoid shortcuts
- ✔ Provide appropriate documentation
- ✔ Perform due diligence
- ✔ Monitor audit progress and data points for accuracy
- ✔ Use previous audits and new info to deep dive into findings
- ✔ Prioritise deep dives as required

🔴 Complete and share the results

- ✔ A security audit is focused on uncovering risk; stay focused on it
- ✔ Share results with all previously determined parties
- ✔ Create a list of action items based on audit findings
- ✔ Prioritise fixes to remediate security items discovered

✔ Source: <https://www.varonis.com/blog/security-audit>



Assessment Types

- 🦊 One time: For special events eg introduction of new software
- 🦊 Tollgate: yes or no response to using a new process
- 🦊 Portfolio: Regularly scheduled audits to verify and assess procedures

🦊 Source: <https://www.varonis.com/blog/security-audit>

Stitching Auditing through the Work Processes



- 🦊 Consult on improving internal controls all through the work process
- 🦊 Discuss them with company teams
- 🦊 Get involved early in the development/design stage
- 🦊 Conduct informal audits
- 🦊 Share learnings

Thank You!

Contact details:

Mob: +91 98230 80864

shweta@sccybersolutions.com

www.sccybersolutions.com

[@sccs1300](#)

